

PROYECTO GAMMA — Γ

Análisis Completo de Funcionalidades del Sistema

Sistema de Gestión de Expedientes Médicos

Hospital Gubernamental · Fase de Diseño

Equipo Gamma · Universidad Tecnológica de Panamá

Stack: Python · PyQt6 · PostgreSQL · SQLAlchemy

Arquitectura: Clean Architecture · SOLID · Repository
Pattern

Perspectivas: Healthcare Analyst · Software Architect · Database Engineer · Security Engineer

Introducción y Alcance del Documento

Este documento contiene el análisis técnico completo de las 7 funcionalidades principales del sistema Gamma, desarrollado conforme a las instrucciones maestras del proyecto y las fuentes oficiales: ProyectoGamma_v2_Completa y Gamma_Parcial1_Documentación.

Cada funcionalidad se analiza desde cuatro perspectivas simultáneas:

- Healthcare Analyst — dominio clínico y flujos hospitalarios reales.
- Software Architect — decisiones de arquitectura, Clean Architecture, impacto en el sistema.
- Database Engineer — entidades, relaciones y decisiones de base de datos PostgreSQL.
- Security Engineer — controles de seguridad bajo ISO 27799, RBAC, auditoría y protección de datos médicos.

Funcionalidades cubiertas:

- M1 — Registro de Pacientes
- M2 — Actualización de Expedientes Médicos
- M3 — Acceso y Consulta de Expedientes
- M4 — Generación de Reportes
- M5 — Gestión de Consultas Médicas
- M6 — Gestión de Citas
- M7 — Gestión de Usuarios y Permisos
- M8 — Auditoría de Acciones

Módulo	Métrica de aceptación oficial
M1 — Registro	100% campos obligatorios validados. Datos recuperables en <1s.
M2 — Actualización	Cambios reflejados en <2s. Historial completo, log de cambios activo.
M3 — Consulta	Respuesta <3s. Búsqueda devuelve expediente correcto al 100%.
M4 — Reportes	Sin errores estadísticos. Generación en <10s para 100 registros.
M5 — Consultas	Registro de consulta en <2s. Historial ordenado cronológicamente.
M6 — Citas	Confirmación de cita en <1s. Sin solapamiento de horarios.
M7 — Usuarios	Cambio de rol efectivo en <1s. 0 accesos no autorizados.
M8 — Auditoría	100% de acciones críticas registradas. Logs inmutables.

M1 Registro de Pacientes

1. Objetivo

Digitalizar el proceso de registro inicial de pacientes, reemplazando el proceso manual de admisión con un formulario estructurado que capture datos de identificación, antecedentes médicos y datos de la visita actual, garantizando que el expediente digital quede disponible de manera inmediata para el personal clínico autorizado.

2. Requisitos Funcionales

ID	Requisito Funcional
RF-M1-01	Registrar datos de identificación: nombre completo, cédula/ID, fecha de nacimiento, género, nacionalidad, dirección, teléfono y contacto de emergencia.
RF-M1-02	Registrar datos médicos iniciales: tipo de sangre, alergias, enfermedades crónicas, medicamentos actuales, antecedentes familiares, vacunas y cirugías previas.
RF-M1-03	Registrar datos de la visita: motivo de consulta, fecha/hora de ingreso, médico tratante, área/especialidad, signos vitales, diagnóstico preliminar y plan de tratamiento.
RF-M1-04	Validar el 100% de los campos obligatorios antes de permitir el guardado.
RF-M1-05	Verificar si ya existe expediente previo por cédula/ID antes de crear uno nuevo.
RF-M1-06	Generar número de expediente único automáticamente al crear un nuevo paciente.
RF-M1-07	Permitir búsqueda de pacientes por nombre, cédula o número de expediente.
RF-M1-08	Solo el rol Recepción/Admisiones puede iniciar el registro de un nuevo paciente.
RF-M1-09	Notificar si se intenta registrar una cédula ya existente, ofreciendo abrir el expediente existente.
RF-M1-10	Al completar el registro, crear automáticamente el expediente base para M2 y M3.

3. Requisitos No Funcionales

Categoría	Requisito
Rendimiento	El registro debe guardarse y confirmarse en menos de 1 segundo.
Disponibilidad	El módulo debe estar operativo al menos el 99.9% del tiempo en horario hospitalario.
Usabilidad	El flujo de registro completo debe completarse sin asistencia por al menos el 80% del personal (UAT).
Integridad	Cada campo obligatorio debe validarse en frontend (PyQt6) Y en backend/service layer.
Trazabilidad	Toda creación de expediente queda en log de auditoría con usuario, fecha, hora e IP.
Estándares	Los campos del formulario siguen el estándar HL7 FHIR / OPS para expedientes hospitalarios.
Compatibilidad	La interfaz debe funcionar correctamente en el entorno PyQt6 de escritorio del hospital.

4. Riesgos

ID	Riesgo	Nivel	Mitigación
R-M1-01	Duplicación de pacientes por falta de validación de cédula	ALTO	Búsqueda obligatoria por cédula antes de habilitar el formulario de nuevo registro.
R-M1-02	Resistencia del personal de recepción a usar el sistema	ALTO	Sesiones de validación de prototipo con representantes del área antes del desarrollo final.
R-M1-03	Datos heredados de registros manuales inconsistentes	MEDIO	Pipeline de limpieza de datos separado del módulo M1 para migraciones.
R-M1-04	Formulario bloquea guardado en urgencias por campos faltantes	MEDIO	Modo urgencia con campos marcables como pendiente para completar posteriormente.
R-M1-05	Violación de privacidad por pantalla abierta o log mal configurado	ALTO	Sesión con timeout de 5 min, cifrado en tránsito y reposo, acceso exclusivo por roles.

5. Casos de Uso

ID	Nombre	Actor	Descripción
CU-M1-01	Registrar nuevo paciente	Recepcionista	Completa formulario de datos de identificación, médicos y visita. El sistema valida y genera el expediente.
CU-M1-02	Buscar paciente existente	Recepcionista	Busca por cédula/nombre antes de crear nuevo registro para evitar duplicados.
CU-M1-03	Abrir expediente existente	Recepcionista	Si el paciente ya tiene expediente, el sistema redirige al expediente existente.
CU-M1-04	Registrar en modo urgencia	Recepcionista	Registro parcial con datos mínimos en situaciones críticas, marcando campos como pendiente.
CU-M1-05	Validar cédula duplicada	Sistema	Al ingresar cédula ya registrada, alerta y ofrece abrir el expediente existente.
CU-M1-06	Auditar registro	Sistema/Adm in	Cada creación queda registrada automáticamente en el log de auditoría.

6. Entidades Involucradas

Entidad	Campos Principales	Relaciones Clave
Paciente	cedula, nombre_completo, fecha_nacimiento, genero, nacionalidad, direccion, telefono, contacto_emergencia	1:1 con ExpedienteMedico
ExpedienteMedico	nro_expediente (único), estado, fecha_creacion, id_paciente_fk	1:N con VisitaClinica; 1:1 con DatosMedicos
DatosMedicosIniciales	tipo_sangre, alergias, enfermedades_cronicas, medicamentos, antecedentes_familiares, vacunas, cirugias	N:1 con ExpedienteMedico

VisitaClinica	motivo_consulta, fecha_hora_ingreso, id_medico_fk, signos_vitales, diagnostico_preliminar	N:1 con ExpedienteMedico
AuditoriaAccion	id_usuario_fk, timestamp, ip_origen, accion, descripcion	N:1 con Usuario

7. Controles de Seguridad (Security Engineer)

Control	Descripción
RBAC estricto	Solo el rol RECEPCIONISTA puede ejecutar la acción de crear nuevo paciente. Todo intento de otro rol se rechaza con log de auditoría.
Validación dual	Toda entrada del formulario se valida primero en PyQt6 (frontend) y luego obligatoriamente en el service layer (backend).
Prevención SQL Injection	Usar exclusivamente SQLAlchemy ORM con parámetros vinculados. Nunca concatenación de strings en consultas.
Auditoría inmutable	Cada creación registra: id_usuario, timestamp, ip_origen, nro_expediente_creado, accion=CREAR_PACIENTE. El log no puede ser editado por ningún rol.
Timeout de sesión	Sesión inactiva por más de 5 minutos bloquea el formulario. Requiere reautenticación para continuar.

8. Impacto en el Sistema

Área impactada	Descripción del impacto
Arquitectura	M1 es el módulo fundacional. Su modelo de datos debe ser estable y extensible para soportar M2, M3 y M4 sin reestructurar tablas base.
Base de datos	Creación de 4 tablas: pacientes, expedientes_medicos, datos_medicos_iniciales, visitas_clinicas. Índice obligatorio en cedula y nro_expediente.
Seguridad	Es la puerta de entrada al sistema. Un registro incorrecto contamina todo el historial clínico posterior. Validación de rol crítica.
M2 — Actualización	No puede funcionar sin expediente base creado por M1.
M3 — Consulta	Depende de que M1 haya registrado los datos completos para devolverlos en consultas.
M4 — Reportes	Usará los datos de registro para estadísticas demográficas y de admisión.

M2 Actualización de Expedientes Médicos

1. Objetivo

Permitir al personal clínico autorizado (médicos y enfermeras) agregar y editar información en el expediente de un paciente existente: notas médicas, diagnósticos, tratamientos, signos vitales y resultados de laboratorio, garantizando trazabilidad completa de cada cambio y que ninguna información previa sea eliminada o sobreescrita sin registro.

2. Requisitos Funcionales

ID	Requisito Funcional
RF-M2-01	El médico puede agregar notas médicas, diagnósticos y planes de tratamiento al expediente.
RF-M2-02	La enfermera puede registrar signos vitales y observaciones de enfermería.
RF-M2-03	Los cambios deben reflejarse en el expediente en menos de 2 segundos.
RF-M2-04	El sistema debe mantener historial completo de todas las versiones de cada campo modificado.
RF-M2-05	Ningún dato previo puede ser eliminado; solo se puede agregar nueva información o marcar registros como corregidos con trazabilidad.
RF-M2-06	El médico debe poder agregar una firma digital al guardar notas médicas.
RF-M2-07	El sistema debe registrar en el log de auditoría: qué campo se modificó, valor anterior, valor nuevo, usuario, fecha y hora.
RF-M2-08	La enfermera solo puede editar campos de su competencia (signos vitales, observaciones). No puede modificar diagnósticos ni tratamientos.
RF-M2-09	Permitir adjuntar resultados de laboratorio o imágenes asociadas al expediente.
RF-M2-10	El expediente debe mostrar todos los cambios en orden cronológico descendente.

3. Requisitos No Funcionales

Categoría	Requisito
Rendimiento	Cambios reflejados en <2s (criterio oficial del proyecto).
Integridad	Historial completo sin pérdida de datos. Transacciones ACID en PostgreSQL.
Trazabilidad	Log de cambios activo y consultable para auditorías. Inmutable.
Concurrencia	Si dos usuarios intentan editar el mismo expediente simultáneamente, el sistema debe gestionar el conflicto con bloqueo optimista.
Disponibilidad	Debe operar al menos 99.9% del tiempo en horario hospitalario.

4. Riesgos

ID	Riesgo	Nivel	Mitigación
R-M2-01	Pérdida accidental de datos clínicos por sobreescritura	ALTO	Nunca sobrescribir; cada cambio genera nueva versión con referencia a la anterior.

R-M2-02	Edición no autorizada por rol incorrecto	ALTO	RBAC granular: validar a nivel de campo qué rol puede editar cada sección.
R-M2-03	Conflicto de edición simultánea del mismo expediente	MEDIO	Bloqueo optimista con timestamp de última modificación; notificar al segundo usuario.
R-M2-04	Firma digital no válida o ausente en notas médicas	MEDIO	Implementar firma digital con hash vinculado al id_usuario y timestamp del sistema.
R-M2-05	Performance degradada con expedientes muy extensos	MEDIO	Paginación del historial; cargar solo los últimos N registros por defecto.

5. Casos de Uso

ID	Nombre	Actor	Descripción
CU-M2-01	Agregar nota médica	Médico	El médico abre el expediente, redacta nota con diagnóstico/tratamiento y la firma digitalmente.
CU-M2-02	Registrar signos vitales	Enfermera	La enfermera selecciona paciente, abre vista restringida y registra presión, temperatura y saturación O2.
CU-M2-03	Corregir un dato previo	Médico	El médico marca un dato previo como corrección, ingresa el dato correcto y deja registro de la corrección.
CU-M2-04	Ver historial de cambios	Médico/Admin	Consultar todas las versiones anteriores de un campo del expediente con autor y timestamp.
CU-M2-05	Adjuntar resultado de laboratorio	Médico	El médico adjunta archivo PDF o imagen del resultado y lo vincula a la visita clínica correspondiente.
CU-M2-06	Auditar modificación	Sistema	Cada modificación queda registrada automáticamente: campo, valor anterior, valor nuevo, usuario.

6. Entidades Involucradas

Entidad	Campos Principales	Relaciones Clave
HistorialCambio	id_expediente_fk, campo_modificado, valor_anterior, valor_nuevo, id_usuario_fk, timestamp	N:1 con ExpedienteMedico
NotaMedica	id_expediente_fk, contenido, diagnostico, tratamiento, firma_digital, id_medico_fk, timestamp	N:1 con ExpedienteMedico
RegistroSignosVitales	id_expediente_fk, presion, temperatura, saturacion_o2, id_enfermera_fk, timestamp	N:1 con ExpedienteMedico
AdjuntoClinico	id_expediente_fk, tipo_archivo, ruta_almacenamiento, descripcion, id_usuario_fk, timestamp	N:1 con ExpedienteMedico

7. Controles de Seguridad (Security Engineer)

Control	Descripción
RBAC granular	A nivel de campo: el médico edita diagnósticos/tratamientos; la enfermera solo signos vitales y observaciones. Validación en service layer.
Inmutabilidad	Nunca se ejecutan UPDATE sobre datos clínicos existentes. Solo INSERT de nuevas versiones con referencia al registro previo.
Firma digital	Cada nota médica genera un hash (SHA-256) del contenido + id_usuario + timestamp, almacenado junto al registro para verificación posterior.
Auditoría de cambios	Log detallado por campo: campo, valor_anterior, valor_nuevo, id_usuario, timestamp. No editable ni eliminable por ningún rol.
Bloqueo de sesión	Timeout de sesión activo. En formularios de edición, el bloqueo se activa a los 5 minutos de inactividad.

8. Impacto en el Sistema

Área impactada	Descripción del impacto
Depende de M1	No puede operar sin el expediente base creado por M1. La entidad ExpedienteMedico de M1 es su punto de partida.
Alimenta a M3	Toda actualización en M2 debe ser visible inmediatamente en M3 (consulta). Requiere coherencia de lectura en la BD.
Alimenta a M4	El historial generado por M2 es la fuente de estadísticas clínicas en M4 (evolución de diagnósticos, tratamientos más frecuentes).
Arquitectura	Requiere una capa de versionado de datos en el Repository Pattern para implementar el historial de cambios sin romper el modelo base de M1.

M3 Acceso y Consulta de Expedientes

1. Objetivo

Proporcionar al personal clínico autorizado un acceso rápido, seguro y filtrado al historial clínico completo de un paciente, permitiendo buscar expedientes por múltiples criterios, visualizar el historial de visitas, diagnósticos, notas médicas y signos vitales, con control estricto de qué información es visible según el rol del usuario.

2. Requisitos Funcionales

ID	Requisito Funcional
RF-M3-01	Permitir búsqueda de expedientes por nombre, cédula, número de expediente, médico tratante y fecha de atención.
RF-M3-02	El tiempo de respuesta de cualquier búsqueda debe ser menor a 3 segundos.
RF-M3-03	El resultado de búsqueda debe ser el expediente correcto al 100% (sin falsos positivos ni negativos).
RF-M3-04	El médico puede ver el historial clínico completo: notas, diagnósticos, tratamientos, signos vitales, adjuntos.
RF-M3-05	La enfermera solo puede ver la vista restringida: signos vitales y observaciones de enfermería.
RF-M3-06	El administrador puede ver el expediente en modo solo lectura para auditoría.
RF-M3-07	Cada acceso de consulta a un expediente queda registrado en el log de auditoría.
RF-M3-08	La interfaz debe mostrar el historial en orden cronológico descendente con posibilidad de filtrar por rango de fechas.
RF-M3-09	El sistema debe mostrar alertas visuales ante alergias o condiciones críticas del paciente al abrir su expediente.
RF-M3-10	Debe existir una función de búsqueda rápida desde el dashboard principal sin necesidad de navegar menús.

3. Requisitos No Funcionales

Categoría	Requisito
Rendimiento	Tiempo de respuesta <3s en cualquier dispositivo (criterio oficial).
Precisión	Búsqueda devuelve expediente correcto al 100%. Sin falsos positivos.
Seguridad	Cada consulta requiere sesión activa y rol autorizado. Ningún dato médico accesible sin autenticación.
Trazabilidad	Todo acceso de lectura a un expediente queda en el log de auditoría.
Usabilidad	≥80% del personal debe completar una consulta sin asistencia (UAT).

4. Riesgos

ID	Riesgo	Nivel	Mitigación
----	--------	-------	------------

R-M3-01	Acceso no autorizado a expedientes de pacientes	ALTO	Validar sesión activa y permisos en cada consulta. Registro en auditoría de todos los accesos.
R-M3-02	Rendimiento degradado con miles de registros en BD	ALTO	Índices en columnas de búsqueda frecuente (cedula, nro_expediente, id_medico, fecha_ingreso).
R-M3-03	Vista incorrecta según rol (enfermera ve diagnósticos)	ALTO	Capa de presentación controlada por rol en el service layer, no solo en la UI.
R-M3-04	Búsqueda devuelve expediente equivocado (homónimos)	MEDIO	Mostrar datos de confirmación (cédula + fecha_nacimiento) antes de abrir el expediente.
R-M3-05	Alergia crítica no visible al abrir expediente	MEDIO	Banner de alerta automático para alergias marcadas como críticas al cargar el expediente.

5. Casos de Uso

ID	Nombre	Actor	Descripción
CU-M3-01	Buscar expediente	Médico/Enfermera/Admin	El usuario ingresa criterios de búsqueda. El sistema devuelve la lista de resultados en <3s.
CU-M3-02	Ver historial clínico completo	Médico	El médico abre un expediente y visualiza todo el historial ordenado cronológicamente.
CU-M3-03	Ver vista restringida	Enfermera	La enfermera abre el expediente en vista limitada: solo signos vitales y observaciones de enfermería.
CU-M3-04	Ver expediente en modo auditoría	Administrador	El admin accede en modo solo lectura para verificar integridad del historial.
CU-M3-05	Filtrar historial por fecha	Médico	El médico filtra las entradas del expediente por rango de fechas para localizar información específica.
CU-M3-06	Registrar acceso en auditoría	Sistema	Cada apertura de un expediente genera entrada automática en el log: quién accedió, cuándo y qué expediente.

6. Entidades Involucradas

Entidad	Campos Principales	Relaciones Clave
ExpedienteMedico	nro_expediente, id_paciente_fk, estado, fecha_creacion	Entidad raíz de consulta
VistaExpediente	Vista lógica que agrega: NotaMedica, RegistroSignosVitales, AdjuntoClinico	Generada por query, no tabla física
LogAccesoExpediente	id_expediente_fk, id_usuario_fk, timestamp_acceso, tipo_acceso (lectura/escritura), ip_origen	N:1 con ExpedienteMedico y Usuario
AlertaCritica	id_expediente_fk, tipo_alerta (alergia/condicion), descripcion, activa	N:1 con ExpedienteMedico

7. Controles de Seguridad (Security Engineer)

Control	Descripción
Autenticación obligatoria	Ninguna consulta es posible sin sesión activa. El token de sesión se valida en cada request al service layer.
Vistas por rol	El service layer determina qué campos se devuelven según el rol del usuario. La UI solo renderiza lo que el backend envía.
Log de acceso de lectura	Incluso leer un expediente genera log de auditoría. Permite detectar accesos masivos o no justificados.
Sin caché de datos médicos	Los datos del expediente no se almacenan en caché del cliente. Cada consulta va al backend para garantizar datos actualizados.
Confirmación de identidad	Al buscar por nombre (posible homonimia), mostrar cédula y fecha de nacimiento para confirmar identidad antes de abrir el expediente.

8. Impacto en el Sistema

Área impactada	Descripción del impacto
Depende de M1 y M2	Requiere expediente base de M1 y los datos actualizados de M2 para devolver información relevante.
Alimenta a M4	Las consultas frecuentes y patrones de acceso pueden alimentar reportes de uso del sistema en M4.
Impacto en BD	Requiere índices optimizados en múltiples columnas. Queries de lectura deben ser de solo lectura para no generar bloqueos.
Arquitectura	El Repository Pattern debe separar claramente las operaciones de lectura (QueryRepository) de las de escritura (CommandRepository).

M4 Generación de Reportes

1. Objetivo

Proveer al personal administrativo y directivo del hospital la capacidad de generar reportes estadísticos y operativos sobre pacientes, expedientes, consultas y diagnósticos, con datos precisos y sin errores estadísticos, permitiendo la toma de decisiones basada en información actualizada del sistema.

2. Requisitos Funcionales

ID	Requisito Funcional
RF-M4-01	Generar reportes de pacientes registrados por período, área, especialidad y médico tratante.
RF-M4-02	Generar reportes estadísticos de diagnósticos más frecuentes, enfermedades crónicas prevalentes y tratamientos aplicados.
RF-M4-03	Generar reportes de actividad del sistema: accesos por usuario, módulos utilizados y acciones auditadas.
RF-M4-04	Los reportes deben generarse en menos de 10 segundos para conjuntos de hasta 100 registros.
RF-M4-05	Los reportes deben estar libres de errores estadísticos (criterio oficial del proyecto).
RF-M4-06	El sistema debe permitir filtrar reportes por rango de fechas, área médica y médico tratante.
RF-M4-07	Los reportes deben poder exportarse en formato PDF o imprimirse directamente desde la interfaz.
RF-M4-08	Solo los roles Admin, Director Médico y Jefes de Departamento pueden generar reportes.
RF-M4-09	Los reportes no deben exponer datos de identificación personal de pacientes en vistas de acceso generalizado (anonimización para reportes estadísticos públicos).
RF-M4-10	El sistema debe mostrar un dashboard de indicadores clave al ingresar al módulo de reportes.

3. Requisitos No Funcionales

Categoría	Requisito
Rendimiento	Generación de reportes en <10s para 100 registros (criterio oficial).
Precisión	Sin errores estadísticos. Los cálculos deben ser verificables y reproducibles.
Seguridad	Reportes con datos personales solo accesibles por roles autorizados. Reportes estadísticos anonimizados.
Escalabilidad	El módulo debe mantener performance con crecimiento del volumen de datos.
Exportación	Salida en PDF generado en el servidor, no en el cliente, para garantizar consistencia de formato.

4. Riesgos

ID	Riesgo	Nivel	Mitigación
----	--------	-------	------------

R-M4-01	Datos inconsistentes producen errores estadísticos en reportes	ALTO	Validar integridad referencial en BD antes de ejecutar queries de reporte. Tests de datos.
R-M4-02	Reporte expone datos personales a roles no autorizados	ALTO	Anonimización automática según tipo de reporte y rol del usuario que lo genera.
R-M4-03	Queries complejos degradan el rendimiento de toda la base de datos	MEDIO	Ejecutar queries de reportes en réplica de lectura o en ventanas horarias de baja carga.
R-M4-04	Reporte generado con rango de fechas incorrecto por error de usuario	BAJO	Validar rango de fechas con confirmación visual antes de ejecutar. Mostrar preview de parámetros.

5. Casos de Uso

ID	Nombre	Actor	Descripción
CU-M4-01	Generar reporte de admisiones	Admin/Director	Genera listado de pacientes admitidos en un período con totales por área y especialidad.
CU-M4-02	Generar reporte de diagnósticos	Admin/Director	Genera estadísticas de diagnósticos más frecuentes en el período seleccionado.
CU-M4-03	Generar reporte de actividad	Admin/TI	Genera reporte de uso del sistema: accesos, acciones por usuario y módulos utilizados.
CU-M4-04	Exportar reporte a PDF	Admin/Director	El usuario genera el reporte y lo exporta en formato PDF para impresión o archivo.
CU-M4-05	Ver dashboard de indicadores	Admin/Director	Al ingresar al módulo, el sistema muestra KPIs actualizados: total pacientes, consultas del día, alertas.
CU-M4-06	Filtrar reporte por parámetros	Admin/Director	El usuario define filtros (fecha, área, médico) y el sistema regenera el reporte con los nuevos parámetros.

6. Entidades Involucradas

Entidad	Campos Principales	Relaciones Clave
VistaReporteAdmisiones	nro_expediente, nombre_paciente (anonizable), area, especialidad, medico, fecha_ingreso	Vista SQL sobre pacientes y expedientes
VistaReporteDiagnosticos	diagnostico, cantidad, porcentaje, area, periodo	Vista SQL sobre visitas_clinicas y notas_medicas
VistaActividadUsuarios	id_usuario, nombre_usuario, total_accesos, ultimo_acceso, modulos_usados	Vista SQL sobre auditoria_acciones
ConfiguracionReporte	id_reporte, tipo, filtros_json, id_usuario_generador_fk, timestamp_generacion	Historial de reportes generados

7. Controles de Seguridad (Security Engineer)

Control	Descripción
---------	-------------

Control de acceso al módulo	Solo roles Admin, Director Médico y Jefes de Departamento pueden acceder al módulo M4. Validado en service layer.
Anonimización	Los reportes estadísticos públicos o compartibles nunca incluyen nombre, cédula ni datos de contacto del paciente.
Queries en réplica	Los reportes complejos ejecutan contra réplica de lectura de PostgreSQL para no afectar la disponibilidad del sistema principal.
Auditoría de reportes	Cada reporte generado queda registrado: qué reporte, con qué filtros, por quién y cuándo. Los reportes no pueden ser alterados post-generación.

8. Impacto en el Sistema

Área impactada	Descripción del impacto
Consume M1, M2, M3	Los datos de todos los módulos anteriores son fuente de los reportes. La calidad de M4 depende directamente de la calidad de los datos en M1-M3.
Impacto en BD	Requiere índices de cobertura en columnas de filtrado frecuente. Considerar réplica de lectura para queries pesados.
Arquitectura	El módulo de reportes debe estar en app/reports/ separado del core del sistema. Usa solo repositorios de lectura.

M5 Gestión de Consultas Médicas

1. Objetivo

Gestionar el ciclo completo de una consulta médica dentro del hospital: desde la apertura de la consulta hasta su cierre y archivo, registrando diagnósticos, prescripciones, referencias a especialistas y resultados de laboratorio, vinculando cada consulta al expediente del paciente y garantizando que el historial clínico sea continuo y trazable.

2. Requisitos Funcionales

ID	Requisito Funcional
RF-M5-01	El médico puede abrir una nueva consulta vinculada al expediente del paciente.
RF-M5-02	Cada consulta registra: motivo, fecha/hora, médico responsable, diagnóstico CIE-10, prescripciones y plan de seguimiento.
RF-M5-03	El médico puede emitir referencias a otras especialidades desde la consulta.
RF-M5-04	El médico puede solicitar exámenes de laboratorio e imagenología vinculados a la consulta.
RF-M5-05	El sistema debe permitir adjuntar resultados a la consulta una vez disponibles.
RF-M5-06	El registro de consulta debe guardarse en menos de 2 segundos.
RF-M5-07	El médico puede cerrar la consulta cuando concluye la atención, impidiendo modificaciones posteriores sin registro de corrección.
RF-M5-08	El historial de consultas del paciente debe mostrarse en orden cronológico descendente.
RF-M5-09	La enfermera puede registrar la preparación del paciente (signos vitales pre-consulta) antes de que el médico inicie la atención.
RF-M5-10	Las consultas cerradas deben ser visibles en M3 (consulta de expedientes) pero no editables.

3. Requisitos No Funcionales

Categoría	Requisito
Rendimiento	Registro de consulta guardado en <2s.
Integridad	Cada consulta cerrada es inmutable. Correcciones generan nueva versión con referencia.
Trazabilidad	Cada acción sobre una consulta (creación, edición, cierre) queda en log de auditoría.
Usabilidad	El flujo de apertura → registro → cierre de consulta completable sin asistencia por ≥80% del personal médico.
Estándares	Diagnósticos codificados conforme a CIE-10 (Clasificación Internacional de Enfermedades).

4. Riesgos

ID	Riesgo	Nivel	Mitigación
----	--------	-------	------------

R-M5-01	Consulta queda abierta sin cerrar, generando historial incompleto	ALTO	Alertas automáticas a consultas abiertas por más de N horas sin actividad.
R-M5-02	Diagnóstico con código CIE-10 incorrecto por error del médico	ALTO	Selector de diagnóstico con búsqueda validada contra catálogo CIE-10 oficial.
R-M5-03	Referencia a especialista sin expediente de seguimiento vinculado	MEDIO	Al crear referencia, generar automáticamente registro de consulta pendiente en la especialidad destino.
R-M5-04	Resultados de laboratorio adjuntados a consulta equivocada	MEDIO	Confirmación visual con datos del paciente y fecha de la consulta antes de adjuntar.

5. Casos de Uso

ID	Nombre	Actor	Descripción
CU-M5-01	Abrir nueva consulta	Médico	El médico selecciona paciente, verifica expediente y abre una nueva consulta vinculada.
CU-M5-02	Registrar diagnóstico y prescripción	Médico	El médico ingresa diagnóstico (CIE-10), prescripción y plan de seguimiento durante la consulta.
CU-M5-03	Emitir referencia a especialista	Médico	El médico genera una referencia formal a otra especialidad vinculada a la consulta en curso.
CU-M5-04	Solicitar examen de laboratorio	Médico	El médico solicita exámenes desde la consulta; queda registro de la solicitud y fecha esperada de resultados.
CU-M5-05	Adjuntar resultados	Médico/Enfermera	Se adjunta el resultado del examen a la consulta correspondiente cuando está disponible.
CU-M5-06	Cerrar consulta	Médico	El médico cierra la consulta cuando concluye la atención. La consulta pasa a estado inmutable.
CU-M5-07	Registrar preparación del paciente	Enfermera	La enfermera registra signos vitales y observaciones previas a la consulta médica.

6. Entidades Involucradas

Entidad	Campos Principales	Relaciones Clave
ConsultaMedica	id_expediente_fk, motivo, fecha_hora, id_medico_fk, estado (abierta/cerrada), diagnostico_cie10, prescripcion, plan_seguimiento	N:1 con ExpedienteMedico
ReferenciaEspecialidad	id_consulta_fk, especialidad_destino, motivo_referencia, id_medico_origen_fk, estado	N:1 con ConsultaMedica
SolicitudExamen	id_consulta_fk, tipo_examen, estado, fecha_solicitud, fecha_resultado_esperada	N:1 con ConsultaMedica

ResultadoExamen	id_solicitud_fk, resultado_texto, archivo_adjunto, fecha_resultado, id_usuario_ingreso_fk	1:1 con SolicitudExamen
-----------------	---	-------------------------

7. Controles de Seguridad (Security Engineer)

Control	Descripción
RBAC por fase	Fase preparación: solo enfermera. Fase diagnóstico/prescripción: solo médico. Cierre de consulta: solo médico responsable.
Inmutabilidad post-cierre	Una consulta cerrada no puede ser editada directamente. Solo se permite agregar correcciones con trazabilidad completa.
Validación CIE-10	El código CIE-10 debe validarse contra el catálogo oficial antes de guardar. Rechazar códigos inexistentes o inactivos.
Auditoría de consultas	Cada apertura, edición y cierre de consulta genera entrada en log de auditoría con usuario y timestamp.

8. Impacto en el Sistema

Área impactada	Descripción del impacto
Depende de M1	Requiere expediente base creado por M1.
Extiende M2	Las consultas médicas son el mecanismo principal de actualización del expediente. M2 y M5 comparten el concepto de historial.
Visible en M3	Las consultas cerradas son consultables en M3. Las abiertas son visibles solo para el médico responsable.
Alimenta M4	Las consultas son fuente principal de estadísticas de diagnósticos y actividad clínica en M4.

M6 Gestión de Citas

1. Objetivo

Gestionar la programación, confirmación, modificación y cancelación de citas médicas en el hospital, evitando conflictos de horarios, optimizando la disponibilidad del personal médico y notificando al paciente o contacto de emergencia sobre el estado de su cita.

2. Requisitos Funcionales

ID	Requisito Funcional
RF-M6-01	El personal de recepción puede crear citas para pacientes registrados, seleccionando médico, fecha, hora y especialidad.
RF-M6-02	El sistema debe verificar disponibilidad del médico y sala antes de confirmar la cita.
RF-M6-03	El sistema debe prevenir solapamiento de citas para el mismo médico y mismo horario.
RF-M6-04	La confirmación de cita debe procesarse en menos de 1 segundo.
RF-M6-05	El recepcionista puede modificar o cancelar una cita con al menos 24 horas de anticipación.
RF-M6-06	El sistema debe registrar el motivo de cancelación o modificación de la cita.
RF-M6-07	El médico puede ver su agenda de citas del día desde su dashboard.
RF-M6-08	La recepción puede ver la agenda completa del hospital filtrada por médico, área o fecha.
RF-M6-09	Cada cita debe vincularse al expediente del paciente para facilitar la apertura de consulta cuando el paciente se presente.
RF-M6-10	El sistema debe permitir registrar la asistencia o inasistencia del paciente a la cita.

3. Requisitos No Funcionales

Categoría	Requisito
Rendimiento	Confirmación de cita en <1s.
Integridad	Sin solapamiento de horarios para el mismo médico. Restricción a nivel de BD.
Trazabilidad	Toda creación, modificación y cancelación de cita queda en log de auditoría.
Usabilidad	El flujo de creación de cita completable sin asistencia por ≥80% del personal de recepción.

4. Riesgos

ID	Riesgo	Nivel	Mitigación
R-M6-01	Doble reserva del mismo médico en el mismo horario (race condition)	ALTO	Constraint UNIQUE en BD (id_medico, fecha, hora). Bloqueo pesimista en creación de cita.
R-M6-02	Cita creada para paciente no registrado en el sistema	ALTO	Validación obligatoria de existencia del paciente en M1 antes de habilitar el formulario de cita.

R-M6-03	Cancelación de cita sin registro del motivo	MEDIO	Campo motivo_cancelacion obligatorio en el formulario de cancelación.
R-M6-04	Médico no ve su agenda actualizada a tiempo	MEDIO	El dashboard del médico debe refrescar la agenda al iniciar sesión y al recibir nueva cita.

5. Casos de Uso

ID	Nombre	Actor	Descripción
CU-M6-01	Crear cita	Recepcionista	Selecciona paciente, médico, fecha y hora. El sistema verifica disponibilidad y confirma la cita.
CU-M6-02	Modificar cita	Recepcionista	Cambia fecha, hora o médico de una cita existente, registrando el motivo del cambio.
CU-M6-03	Cancelar cita	Recepcionista	Cancela la cita, registra el motivo y libera el horario del médico.
CU-M6-04	Ver agenda del día	Médico	El médico consulta su agenda de citas del día desde su dashboard al iniciar sesión.
CU-M6-05	Ver agenda del hospital	Recepcionista	Visualiza la agenda completa filtrada por médico, área o rango de fechas.
CU-M6-06	Registrar asistencia	Recepcionista	Cuando el paciente se presenta, registra la asistencia y facilita la apertura de consulta en M5.
CU-M6-07	Registrar inasistencia	Recepcionista	Marca la cita como inasistencia con posibilidad de reagendar.

6. Entidades Involucradas

Entidad	Campos Principales	Relaciones Clave
Cita	id_paciente_fk, id_medico_fk, fecha, hora, especialidad, estado (programada/confirmada/cancelada/completada/inasistencia), motivo, id_usuario_creador_fk	N:1 con Paciente y Usuario
DisponibilidadMedico	id_medico_fk, dia_semana, hora_inicio, hora_fin, activo	N:1 con Usuario (médico)
HistorialCita	id_cita_fk, estado_anterior, estado_nuevo, motivo_cambio, id_usuario_fk, timestamp	N:1 con Cita

7. Controles de Seguridad (Security Engineer)

Control	Descripción
RBAC de citas	Solo Recepcionista puede crear/modificar/cancelar citas. El médico solo tiene vista de lectura de su agenda.
Constraint anti-solapamiento	UNIQUE constraint en (id_medico, fecha, hora) en BD. Validación adicional en service layer antes del INSERT.
Auditoría de cambios	Todo cambio de estado de cita (programada→cancelada, etc.) queda en HistorialCita con motivo y usuario responsable.

Validación de paciente	No se puede crear cita para un paciente que no exista en la tabla pacientes de M1.
------------------------	--

8. Impacto en el Sistema

Área impactada	Descripción del impacto
Depende de M1	El paciente debe estar registrado en M1 para poder crear una cita.
Facilita M5	Al registrar la asistencia a una cita, el sistema puede pre-cargar el expediente del paciente para facilitar la apertura de consulta en M5.
Alimenta M4	Las estadísticas de citas (asistencias, cancelaciones, especialidades más solicitadas) son fuente de reportes en M4.
Agenda médica	El módulo de citas es la fuente de la agenda diaria que el médico ve en su dashboard.

M7 Gestión de Usuarios y Permisos

1. Objetivo

Administrar el ciclo de vida completo de los usuarios del sistema: creación, modificación, desactivación y asignación de roles y permisos, garantizando que cada usuario tenga acceso únicamente a las funcionalidades y datos que le corresponden según su rol clínico o administrativo, con trazabilidad completa de todos los cambios de acceso.

2. Requisitos Funcionales

ID	Requisito Funcional
RF-M7-01	Solo el rol Administrador de TI puede crear, modificar y desactivar usuarios.
RF-M7-02	Cada usuario debe tener un rol asignado: Recepcionista, Enfermera, Médico General, Médico Especialista, Director Médico, Admin/TI.
RF-M7-03	El sistema debe usar bcrypt para el hash de contraseñas. Las contraseñas nunca se almacenan en texto plano.
RF-M7-04	Las contraseñas deben cumplir política de complejidad: mínimo 8 caracteres, al menos 1 mayúscula, 1 número y 1 carácter especial.
RF-M7-05	El cambio de rol de un usuario debe ser efectivo en menos de 1 segundo.
RF-M7-06	Al desactivar un usuario, su sesión activa debe cerrarse inmediatamente.
RF-M7-07	Un usuario desactivado no puede iniciar sesión ni acceder al sistema bajo ninguna circunstancia.
RF-M7-08	El administrador puede restablecer la contraseña de un usuario generando una contraseña temporal de un solo uso.
RF-M7-09	El sistema debe registrar en auditoría cada cambio de rol, desactivación o restablecimiento de contraseña.
RF-M7-10	Los permisos se gestionan a nivel de rol, no a nivel de usuario individual, para simplificar la administración.

3. Requisitos No Funcionales

Categoría	Requisito
Seguridad	0 accesos no autorizados. Contraseñas hasheadas con bcrypt. Sin contraseñas en texto plano en ningún log ni BD.
Rendimiento	Cambio de rol efectivo en <1s.
Trazabilidad	100% de cambios de acceso (roles, contraseñas, estados) registrados en auditoría inmutable.
Principio de mínimo privilegio	Cada rol tiene únicamente los permisos necesarios para sus funciones. Sin permisos adicionales por defecto.

4. Riesgos

ID	Riesgo	Nivel	Mitigación
----	--------	-------	------------

R-M7-01	Contraseña almacenada o transmitida en texto plano	CRÍTICO	bcrypt obligatorio. Sin logging de contraseñas. HTTPS en toda comunicación.
R-M7-02	Usuario desactivado sigue con sesión activa	ALTO	Al desactivar, invalidar token de sesión activa inmediatamente en el server.
R-M7-03	Escalada de privilegios por asignación incorrecta de rol	ALTO	Validar que solo Admin/TI puede modificar roles. Auditoría inmediata de cambios de rol.
R-M7-04	Cuenta de Admin/TI comprometida da acceso total al sistema	CRÍTICO	Autenticación de dos factores para el rol Admin/TI. Auditoría en tiempo real de sus acciones.
R-M7-05	Contraseña temporal no cambiada por el usuario tras restablecimiento	MEDIO	Forzar cambio de contraseña en el primer inicio de sesión con contraseña temporal.

5. Casos de Uso

ID	Nombre	Actor	Descripción
CU-M7-01	Crear usuario	Admin/TI	El administrador crea un nuevo usuario asignando nombre, credenciales iniciales y rol.
CU-M7-02	Asignar/cambiar rol	Admin/TI	El administrador modifica el rol de un usuario existente. El cambio es efectivo inmediatamente.
CU-M7-03	Desactivar usuario	Admin/TI	El administrador desactiva la cuenta de un usuario. La sesión activa se cierra de inmediato.
CU-M7-04	Restablecer contraseña	Admin/TI	El administrador genera una contraseña temporal de un solo uso. El usuario debe cambiarla en el próximo login.
CU-M7-05	Cambiar contraseña propia	Usuario	El usuario autenticado puede cambiar su propia contraseña cumpliendo la política de complejidad.
CU-M7-06	Consultar usuarios activos	Admin/TI	El administrador puede listar todos los usuarios activos, sus roles y último acceso.
CU-M7-07	Auditar cambios de acceso	Admin/TI	El administrador puede consultar el historial completo de cambios de rol y contraseña.

6. Entidades Involucradas

Entidad	Campos Principales	Relaciones Clave
Usuario	id, nombre_completo, username, password_hash, rol, estado (activo/inactivo), ultimo_acceso, fecha_creacion, id_creador_fk	Entidad central de autenticación
Rol	id, nombre, descripcion, permisos_json	1:N con Usuario
SesionActiva	id_usuario_fk, token_sesion, timestamp_inicio, ip_origen, activa	N:1 con Usuario
AuditoriaCambioAcceso	id_usuario_afectado_fk, id_admin_fk, tipo_cambio (rol/password/estado),	Registro inmutable

	valor_anterior, valor_nuevo, timestamp	
--	---	--

7. Controles de Seguridad (Security Engineer)

Control	Descripción
bcrypt obligatorio	Las contraseñas SIEMPRE se almacenan como hash bcrypt con factor de costo mínimo 12. Nunca en texto plano ni MD5/SHA1.
Política de contraseñas	Mínimo 8 caracteres, 1 mayúscula, 1 número, 1 carácter especial. Validación en el service layer, no solo en la UI.
Principio de mínimo privilegio	Cada rol tiene solo los permisos necesarios. La tabla de permisos por rol se define en la capa de seguridad y no es modificable desde la UI.
Invalidación de sesión	Al desactivar usuario o cambiar rol, el token de sesión activa se invalida en la tabla SesionActiva inmediatamente.
2FA para Admin/TI	El rol Admin/TI requiere autenticación de dos factores para prevenir que una contraseña comprometida dé acceso total al sistema.
Sin contraseñas en logs	Los logs de auditoría nunca registran contraseñas en ninguna forma (ni hash ni texto plano). Solo el tipo de cambio.

8. Impacto en el Sistema

Área impactada	Descripción del impacto
Módulo transversal	M7 es transversal a todo el sistema. Todos los módulos (M1-M6, M8) dependen del sistema de autenticación y roles de M7.
Arquitectura	El módulo de seguridad (app/security/) es independiente de los módulos de negocio. Implementar como middleware de autenticación.
Base de datos	La tabla usuarios es referenciada por todas las tablas de auditoría del sistema. Índice obligatorio en username y en token_sesion.
Impacto en M8	Todos los eventos de M7 (cambios de acceso) son los más críticos para el módulo de auditoría M8.

M8 Auditoría de Acciones del Sistema

1. Objetivo

Garantizar la trazabilidad completa de todas las acciones críticas realizadas por los usuarios del sistema, generando un registro inmutable, consultable y exportable que permita identificar quién hizo qué, cuándo y desde dónde, cumpliendo con los requisitos de ISO 27799 y respondiendo ante auditorías externas del hospital gubernamental.

2. Requisitos Funcionales

ID	Requisito Funcional
RF-M8-01	El sistema debe registrar automáticamente toda acción crítica: creación, modificación, consulta y eliminación de expedientes, cambios de acceso, generación de reportes y errores del sistema.
RF-M8-02	Cada entrada de auditoría debe incluir: id_usuario, rol_usuario, accion, modulo, entidad_afectada, id_entidad, timestamp, ip_origen y resultado (éxito/fallo).
RF-M8-03	Los registros de auditoría son inmutables: ningún usuario, incluyendo Admin/TI, puede editar o eliminar entradas del log.
RF-M8-04	El Administrador puede consultar el log de auditoría filtrando por usuario, módulo, acción, rango de fechas y resultado.
RF-M8-05	Los registros de auditoría deben estar disponibles para consulta en menos de 3 segundos.
RF-M8-06	El sistema debe generar alertas automáticas ante patrones sospechosos: múltiples intentos de login fallidos, acceso masivo a expedientes, cambios de rol fuera de horario laboral.
RF-M8-07	Los logs de auditoría deben poder exportarse en formato PDF o CSV para auditorías externas.
RF-M8-08	El log debe retener registros por un mínimo de 5 años (requisito de datos médicos).
RF-M8-09	Los accesos fallidos (login incorrecto, intento de acceso sin permiso) también deben quedar registrados.
RF-M8-10	El módulo de auditoría no debe impactar el rendimiento del sistema principal en más de 50ms por operación.

3. Requisitos No Funcionales

Categoría	Requisito
Rendimiento	Escritura de log en <50ms. Consulta de log en <3s.
Integridad	100% de acciones críticas registradas. Sin gaps en el log.
Inmutabilidad	Log no modificable por ningún rol. Solo INSERT, nunca UPDATE ni DELETE.
Retención	Mínimo 5 años de retención de logs de acciones sobre datos médicos.
Disponibilidad	El módulo de auditoría debe estar operativo incluso cuando otros módulos fallen.
Cumplimiento	Cumple con ISO 27799:2016 y ISO 27001 en gestión de logs de seguridad.

4. Riesgos

ID	Riesgo	Nivel	Mitigación
R-M8-01	El log de auditoría crece descontroladamente y degrada la BD	ALTO	Tabla de auditoría en esquema separado o BD separada. Archivado automático de registros >1 año.
R-M8-02	Gaps en el log por fallo del sistema durante una operación	ALTO	Escribir el log de auditoría en la misma transacción que la operación de negocio (atomic).
R-M8-03	Log de auditoría accesible a usuarios no autorizados	ALTO	Solo el rol Admin/TI puede consultar el log completo. El personal médico no tiene acceso.
R-M8-04	Alertas de seguridad no notificadas al administrador a tiempo	MEDIO	Sistema de notificaciones en tiempo real para alertas críticas (intentos de intrusión).
R-M8-05	Log escrito fuera de la transacción principal pierde coherencia	MEDIO	Implementar el log como parte de la transacción de negocio, no como operación asíncrona independiente.

5. Casos de Uso

ID	Nombre	Actor	Descripción
CU-M8-01	Registrar acción automáticamente	Sistema	Ante cada acción crítica, el sistema genera una entrada en el log sin intervención del usuario.
CU-M8-02	Consultar log de auditoría	Admin/TI	El administrador filtra el log por usuario, módulo, acción y rango de fechas.
CU-M8-03	Exportar log a CSV/PDF	Admin/TI	El administrador exporta un subconjunto del log para una auditoría externa.
CU-M8-04	Recibir alerta de seguridad	Admin/TI	El sistema detecta patrón sospechoso y notifica al administrador en tiempo real.
CU-M8-05	Registrar intento de acceso fallido	Sistema	Cada login fallido o intento de acceso a módulo sin permiso queda registrado con IP y timestamp.
CU-M8-06	Auditoría externa del hospital	Auditor externo	El administrador genera y entrega el reporte de auditoría para revisión gubernamental.

6. Entidades Involucradas

Entidad	Campos Principales	Relaciones Clave
AuditoriaAccion	id, id_usuario_fk, rol_usuario, modulo, accion, entidad_afectada, id_entidad, timestamp, ip_origen, resultado, descripcion_detalle	Solo INSERT. Tabla central de auditoría.
AlertaSeguridad	id, tipo_alerta, descripcion, timestamp_deteccion, id_usuario_afectado_fk, estado (activa/resuelta), id_admin_notificado_fk	N:1 con AuditoriaAccion
ConfiguracionAlerta	tipo_patron, umbral, ventana_tiempo_minutos, activo	Configuración del motor de alertas

7. Controles de Seguridad (Security Engineer)

Control	Descripción
Solo INSERT	La tabla AuditoriaAccion tiene únicamente permisos de INSERT en el usuario de base de datos de la aplicación. Sin UPDATE ni DELETE.
Transacción atómica	El registro de auditoría se hace dentro de la misma transacción de base de datos que la operación de negocio. Si la operación falla, el log también falla.
Acceso restringido al log	Solo el rol Admin/TI puede consultar el log completo. La consulta también genera una entrada de auditoría de segundo nivel.
Retención por ley	Los logs de acciones sobre expedientes médicos se retienen por mínimo 5 años conforme a regulaciones de datos médicos en Panamá.
Alertas automáticas	Motor de reglas que detecta: >5 logins fallidos en 5 min (mismo IP), >50 consultas de expedientes en 1 hora (mismo usuario), cambios de rol entre las 22:00 y 06:00.
Hash de integridad	Cada bloque de 1000 registros genera un hash de integridad que permite detectar si el log fue manipulado a nivel de archivo.

8. Impacto en el Sistema

Área impactada	Descripción del impacto
Módulo transversal	M8 recibe eventos de TODOS los módulos. Es el tejido conectivo de trazabilidad del sistema Gamma.
Arquitectura	Implementar como servicio independiente en app/security/audit_service.py con su propio repositorio. Los demás módulos lo invocan como dependencia inyectada.
Base de datos	Tabla de auditoría en esquema separado (schema: audit). Índices en (id_usuario, timestamp) y (modulo, accion, timestamp). Archivado automático tras 1 año.
Respuesta ante incidentes	El log de auditoría es la primera fuente de información ante cualquier incidente de seguridad o reclamación. Su integridad es crítica.
Cumplimiento ISO 27799	El módulo de auditoría es el mecanismo principal de cumplimiento con ISO 27799:2016 (seguridad de información médica) e ISO 27001.

Resumen Ejecutivo — Decisiones por Perspectiva

Decisiones de Arquitectura (Software Architect)

Módulo	Decisión arquitectónica clave
M1	Módulo fundacional. Su modelo de datos debe ser estable desde el inicio. Extensión sin reestructurar tablas base.
M2	Requiere capa de versionado en el Repository Pattern. Nunca UPDATE sobre datos clínicos; solo INSERT de nuevas versiones.
M3	Separar QueryRepository (solo lectura) de CommandRepository (escritura). Índices de cobertura obligatorios.
M4	Módulo aislado en app/reports/. Consume solo repositorios de lectura. Queries contra réplica de BD.
M5	Extiende M2 con el ciclo de vida de consulta médica. CIE-10 como catálogo de diagnósticos.
M6	UNIQUE constraint en BD para prevenir solapamiento. Race condition manejada con bloqueo pesimista.
M7	Módulo transversal en app/security/. Implementado como middleware de autenticación para todos los módulos.
M8	Servicio independiente en app/security/audit_service.py. Escritura atómica dentro de la transacción de negocio.

Decisiones de Base de Datos (Database Engineer)

Aspecto	Decisión
Motor	PostgreSQL con soporte ACID completo, cifrado nativo en reposo y soporte HIPAA.
ORM	SQLAlchemy con parámetros vinculados en todas las queries. Sin concatenación de strings.
Versionado	Datos clínicos: solo INSERT de nuevas versiones. Nunca UPDATE sobre registros de historial médico.
Índices críticos	cedula, nro_expediente, id_medico+fecha+hora (UNIQUE), id_usuario+timestamp (auditoría).
Auditoría	Tabla AuditoriaAccion en schema separado. Solo permisos de INSERT para el usuario de la aplicación.
Réplica	Queries de reportes (M4) ejecutados contra réplica de lectura para no degradar el sistema principal.

Controles de Seguridad Transversales (Security Engineer)

Control	Aplicación en el sistema
RBAC	Todos los módulos validan el rol del usuario en el service layer, no solo en la UI.

bcrypt	Contraseñas hasheadas con bcrypt (factor 12). Sin contraseñas en ningún log.
Auditoría inmutable	Log en schema separado. Solo INSERT. Sin UPDATE ni DELETE para ningún rol.
Validación dual	Toda entrada validada en PyQt6 (frontend) Y en el service layer (backend).
Sin SQL injection	Exclusivamente SQLAlchemy ORM con parámetros vinculados en todos los módulos.
Timeout de sesión	5 minutos de inactividad cierra la sesión en todos los módulos.
ISO 27799	Confidencialidad, integridad y disponibilidad de datos médicos garantizados en cada módulo.

Criterios de Aceptación por Módulo (QA / ISTQB CTFL v4.0)

Módulo	Criterio de aceptación oficial	Métrica
M1 — Registro	100% campos obligatorios validados sin errores	Datos recuperables en <1s
M2 — Actualización	Historial completo sin pérdida. Log activo	Cambios en <2s
M3 — Consulta	Expediente correcto al 100%	Respuesta <3s
M4 — Reportes	Sin errores estadísticos. Datos completos	Generación en <10s / 100 registros
M5 — Consultas	Consulta registrada y vinculada al expediente	Guardado en <2s
M6 — Citas	Sin solapamiento de horarios. 0 dobles reservas	Confirmación en <1s
M7 — Usuarios	0 accesos no autorizados. 100% cambios auditados	Cambio de rol en <1s
M8 — Auditoría	100% acciones críticas registradas. Log inmutable	Escritura en <50ms